VULNERABILITY ASSESSMENT FINDINGS LOG

Epotech Cybersecurity Platform — Security Audit Matrix

2	1	2	1	2
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL

EXECUTIVE MATRIX

The following log details all 8 security findings identified during the static source code and configuration audit of the Epotech Cybersecurity Platform. Each vulnerability is mapped to its OWASP Top 10:2025 category, Common Weakness Enumeration (CWE), affected code components, and assigned remediation priority.

ID	TITLE	SEVERITY	OWASP	AFFECTED COMPONENT	PRIORITY	STATUS
EPOTK-001	Email-Based Admin Role Inference — Client-Side Privilege Escalation	CRITICAL	A01/A07:2025	`src/lib/auth.js` `src/pages/AuthPage.jsx`	P1 — Immediate	OPEN
EPOTK-002	Production Secrets Committed to Repository	CRITICAL	A04/A02:2025	`.env` `.env.local`	P1 — Immediate	OPEN
EPOTK-003	Supabase RLS Policies Grant Unauthenticated Full Data Access	HIGH	A01:2025	`supabase_schema.sql`	P1 — Immediate	OPEN
EPOTK-004	Authentication Bypass via Offline Demo Fallback	MEDIUM	A07/A06:2025	`src/pages/AuthPage.jsx`	P2 — High	OPEN
EPOTK-005	Missing HSTS and X-Frame-Options in Vercel Security Headers	MEDIUM	A02:2025	`vercel.json`	P3 — Medium	OPEN
EPOTK-006	No Security Event Logging for Auth Failures	LOW	A09:2025	`src/pages/AuthPage.jsx` `src/App.jsx`	P4 — Low	OPEN
EPOTK-I01	Hardcoded Personal Email Address in Navbar Component	INFO	A02:2025	`src/components/Navbar.jsx`	P5 — Info	OPEN
EPOTK-I02	authConfirmed Checkbox Is Non-Binding and Easily Bypassed	INFO	A06:2025	`src/pages/DashboardPage.jsx`	P5 — Info	OPEN

DETAILED VULNERABILITY BREAKDOWNS (P1 CRITICAL & HIGH)

EPOTK-001: Email-Based Admin Role Inference — Client-Side Privilege Escalation

CRITICAL

OWASP / CWE
A01:2025 / A07:2025 (CWE-284, CWE-602)

REMEDIATION PRIORITY / RETEST
P1 — Immediate | OPEN

AFFECTED COMPONENTS
`src/lib/auth.js` ; `src/pages/AuthPage.jsx` ; `src/App.jsx`

ROOT CAUSE
Role determined strictly by email substring match on client side with no server verification.

TECHNICAL IMPACT
Any user with 'admin' in email gains full admin access; all client data exposed; delete/scan operations accessible.

BUSINESS IMPACT
Complete compromise of client data confidentiality; severe reputational damage for a cybersecurity firm.

EPOTK-002: Production Secrets Committed to Repository

CRITICAL

OWASP / CWE
A04:2025 / A02:2025 (CWE-312, CWE-798)

REMEDIATION PRIORITY / RETEST
P1 — Immediate | OPEN

AFFECTED COMPONENTS
`.env` ; `.env.local`

ROOT CAUSE
Live Supabase URL + Anon Key + Vercel OIDC token stored in version-controlled files.

TECHNICAL IMPACT
Direct database access possible with known credentials; Vercel deployment pipeline potentially compromised.

BUSINESS IMPACT
Full exfiltration of all `service_requests` and `security_audits` data.

EPOTK-003: Supabase RLS Policies Grant Unauthenticated Full Data Access

HIGH

OWASP / CWE
A01:2025 (CWE-284, CWE-732)

REMEDIATION PRIORITY / RETEST
P1 — Immediate | OPEN

AFFECTED COMPONENTS
`supabase_schema.sql`

ROOT CAUSE
SELECT + INSERT + UPDATE granted to `anon` role with `USING (true)` — no user filtering.

TECHNICAL IMPACT
Unauthenticated read of all records; injection of fraudulent records; status manipulation.

BUSINESS IMPACT
All client engagement data publicly accessible; confidential target information exposed.

DETAILED VULNERABILITY BREAKDOWNS (MEDIUM, LOW & INFORMATIONAL)

EPOTK-004: Authentication Bypass via Offline Demo Fallback

MEDIUM

OWASP / CWE
A07:2025 / A06:2025 (CWE-287, CWE-303)

REMEDIATION PRIORITY / RETEST
P2 — High | OPEN

AFFECTED COMPONENTS
`src/pages/AuthPage.jsx`

ROOT CAUSE
Network error catch block grants `localStorage` session with unverified email; demo buttons bypass auth.

IMPACT (TECH & BIZ)
One-click admin access via 'Admin Persona' button; authentication is non-functional in error conditions.

EPOTK-005: Missing HSTS and X-Frame-Options in Vercel Security Headers

MEDIUM

OWASP / CWE
A02:2025 (CWE-16)

REMEDIATION PRIORITY / RETEST
P3 — Medium | OPEN

AFFECTED COMPONENTS
`vercel.json`

ROOT CAUSE & IMPACT
HSTS and X-Frame-Options omitted from configuration; CSP weakened by `'unsafe-inline'`. SSL stripping and clickjacking risks exist.

EPOTK-006: No Security Event Logging for Authentication or Authorization Failures

LOW

OWASP / CWE
A09:2025 (CWE-778)

REMEDIATION PRIORITY / RETEST
P4 — Low | OPEN

AFFECTED COMPONENTS
`src/pages/AuthPage.jsx`; `src/App.jsx`

ROOT CAUSE & IMPACT
Auth failures logged only to browser console; no SIEM/Sentry integration. Brute-force attacks and unauthorized access attempts are completely undetectable.

EPOTK-I01: Hardcoded Personal Email Address in Navbar Component

INFO

OWASP / CWE
A02:2025 (CWE-312)

REMEDIATION PRIORITY / RETEST
P5 — Informational | OPEN

AFFECTED COMPONENT & IMPACT
`src/components/Navbar.jsx` — Unused `ADMIN_EMAIL` constant with personal PII compiled into JS bundle. Potential social engineering vector.

EPOTK-I02: authConfirmed Checkbox Is Non-Binding and Easily Bypassed

INFO

OWASP / CWE
A06:2025 (CWE-602)

REMEDIATION PRIORITY / RETEST
P5 — Informational | OPEN

AFFECTED COMPONENT & IMPACT
`src/pages/DashboardPage.jsx` — Client-side checkbox default true sent to backend; provides no real authorization control without backend verification.